



Plan de Respuesta ante Incidentes

Ciclo NIST - Identificación, Protección, Detección, Respuesta y Recuperación

Autor: Jefferson Moran

Introducción y Alcance

Este plan sigue el ciclo de vida de la guía NIST para asegurar una respuesta sistémica ante un ataque. Los cinco pilares clave son:

1) Identificación
Reconocer el incidente.

5) Recuperación
Restaurar servicios.



2) Protección
Implementar defensas.

3) Detección
Monitorear amenazas.

4) Respuesta
Actuar ante incidentes.

Roles y Responsabilidades

Rol	Responsabilidad
Manager de Incidente (Líder IT/CISO)	Autoriza parada de servicios y coordina comunicación.
Analista Forense (Especialista Seguridad)	Investiga vectores de entrada y busca malware.
Administrador de Sistemas (Técnico Infraestructura)	Ejecuta remediación y saneamiento.
Administrador de BD (DBA)	Asegura integridad MySQL y gestiona credenciales.

Fases de Respuesta ante Incidentes

01

Preparación (Hardening)

Controles de acceso, SSH Keys, Fail2Ban, AIDE, capacitación.

03

Contención y Erradicación

Aislamiento de servicios, saneamiento de archivos, rotación de secretos.

02

Detección y Análisis

Monitoreo de logs sshd/apache2, análisis de impacto.

04

Recuperación y Continuidad

Restauración de datos, RTO <4 horas, RPO <24 horas.

Medidas Preventivas (Roadmap)

1) Parcheo Crítico

Actualizar OpenSSH inmediatamente para mitigar CVE-2024-6387.

2) Defensa Activa

Instalar Fail2Ban para mitigar ataques de fuerza bruta en puerto 22.

3) Monitoreo de Integridad

Implementar AIDE o Tripwire para alertar sobre cambios en wp-config.php.

SGSI – ISO 27001: Análisis de Riesgos

Riesgo	Impacto	Probabilidad
Acceso no autorizado a nivel Root	Muy Alto	Media
Exfiltración de datos por configuraciones web inseguras	Alto	Alta
Pérdida de integridad de datos por falta de backups	Crítico	Media

Políticas de Seguridad de la Información

Política de Control de Acceso

Todo acceso administrativo debe ser individual, con privilegios mínimos y autenticación multifactor (MFA).

Política de Operaciones Seguras

Queda prohibida la existencia de archivos con permisos 777 en servidores de producción.

Política de Gestión de Vulnerabilidades

Se realizarán escaneos trimestrales para parchear CVEs críticos.

Mecanismos de Protección de Datos (Controles Técnicos)

Implementación de defensas técnicas para salvaguardar la información.

Respaldos Periódicos

Backups diarios de MySQL en entorno cifrado y externo, pruebas de restauración trimestrales.

Cifrado de Datos Sensibles

Uso de TLS para tráfico web (HTTPS) y SSH para administración, cifrado de constantes en wp-config.php.

Controles de Acceso Estrictos

Implementación de Options - Indexes en Apache, restricción de permisos en archivos sensibles.

Conclusión: Seguridad Integral

El Plan de Respuesta ante Incidentes es un documento vivo que debe ser revisado y actualizado regularmente. La seguridad es un proceso continuo que requiere:

1) Preparación constante

Entrenamientos y actualizaciones.

2) Vigilancia activa

Monitoreo 24/7 de amenazas.

3) Respuesta rápida

Equipos entrenados y procedimientos claros.

4) Recuperación efectiva

Backups y planes de continuidad.